Code Review

OWASP Code Review Guide, ISO/IEC 25010, CWE, WCAG 2.1 AA | Run date 2026-11-02 (run 5, full re-execution from an empty sandbox). Static checks (npm ci, audit, lint, build, Semgrep, secret scan) ran on main HEAD df46295; main HEAD does not build, so behavioural tests (HTTP, browser, axe, ZAP) ran on 1c85d7d, the last buildable commit (the HEAD moved during the run: 14 commits, 23 files). Tools: node 22.23.4, npm 10.9.9, next 14.2.5 (installed), semgrep 1.183.0, OWASP ZAP 2.16.1 (java 21), playwright-core 1.56.1 (pinned), axe-core 4.10.2 (pinned), curl 8.5.0, reportlab 5.0.1.

1. Build and quality gates (clean sandbox)

Gate	Result	Evidence
npm ci	PASS (363 packages; run 4: FAIL, lockfile out of sync)	02_npm_ci.log
next lint (HEAD df46295)	**FAIL**: 1 error (parsing error: Identifier 'getRecordName' has already been declared, list-your-property/page.js:6091), 11 warnings	03a_lint.log
next build (HEAD df46295)	**FAIL**: 'Build failed because of webpack errors' - the name getRecordName is defined multiple times (list-your-property/page.js lines 4207 and 6091). Commit df46295 added 5,913 lines to that file (now 7,952 lines incl. commented-out and pasted copies). Production cannot be built from main.	03b_build.log
next lint / build (1c85d7d, last buildable commit)	PASS: 0 errors, 9 warnings; build generated 24 pages (informational DYNAMIC_SERVER_USAGE log for /api/wishlist). Run 4: lint error and build failure	03a_lint_1c85d7d.log, 03b_build_1c85d7d.log
Automated tests	None exist (no test files, no test script)	git ls-files
CI	None (no .github/ workflows)	git ls-files
Codebase size	Very large files: list-your-property/page.js 7,952 lines (duplicated/commented copies), ai-search/route.js 1,443, suggestions/route.js 1,385, lead3 1,439, leads 1,044, PropertiesClient.js, Navbar.js	wc -l

2. ISO/IEC 25010 assessment

Characteristic	Rating	Evidence
Functional suitability	Partial	Property browse, detail, compare, wishlist, KYC city pages, AI search and lead forms exist in code; SalesIQ, PageSense, GA4/GTM, view scoring, Catalyst Search and the CRM-to-Catalyst publishing Functions are absent (Scope report).
Performance efficiency	Partial	First-load JS 87-162 kB; listing and detail pages are client-rendered, in-memory caches are per instance; 6 raw <img> usages bypass next/image.
Compatibility	Pass	Responsive: no horizontal scroll at 375 px on any tested page (browser tests LAYOUT).
Usability / accessibility	Fail	axe WCAG 2.1 A/AA: 7 of 18 page-runs have critical/serious violations (select-name, color-contrast, aria-required-parent).
Reliability	Fail	main HEAD does not build (duplicate declaration). Upstream failures are swallowed (micromarkets returns success:true with empty data); lead and cache state is per instance and lost on restart.
Security	Fail	18 findings (0 critical, 4 high, 10 medium, 4 low, 0 info) - see Security report.
Maintainability	Fail	A 7,952-line page file with commented-out and pasted duplicate copies (the cause of the build break), three near-duplicate lead routes (leads 1,044 / lead2 512 / lead3 1,439 lines), stray pages/HomePage.js (a Pages Router file also served at /HomePage), 159 console statements, no tests, no CI, hard-coded IDs, Windows paths in catalyst.json.
Portability	Partial	catalyst.json sources are D:\Catalyst\...; anarock/.catalyst/slate-config.toml tracked; .env.example absent so required variables are only discoverable by reading code.

3. OWASP Code Review Guide mapping

Area	Observation	Ref
Input validation	/api/leads validates names, phone (E.164-like), email, lengths (MAX_LENGTHS), content-type (415) and size (50 KB via Content-Length only). lead2 validates nothing; ai-search/location lack size caps and JSON-error handling.	S-02, S-08, S-15
Output encoding / XSS	No dangerouslySetInnerHTML with user data (JSON-LD blocks and chart.jsx only); title built from slug is escaped by React but spoofable.	S-11
Authn/authz	No user auth. Lead duplicate path updates existing CRM records.	S-04
Error handling	Raw upstream errors and env-var names are returned to clients.	S-06
Logging	159 console statements; prompts and API payloads logged.	S-18
Secrets / config	No secrets in tree/history by regex scan; env names documented only in code; no .env.example.	S-13, S-14
Dependencies	next pinned 14.2.5; 19 audit findings.	S-01
Concurrency / state	Module-level Maps for rate limit, location throttle, token cache and property cache; not serialised, never purged.	S-03, S-15
Crypto / transport	Fixed HTTPS upstream hosts; no HSTS from the app; TLS terminated by Slate (not verifiable, not deployed).	S-07

4. Register of missing items

Item	Status	Detail / evidence
Catalyst Functions required by SoW (CRM sync, Gemini attribute generation, validation routing, lead capture, view scoring, revalidation)	Missing	Repo has no functions/ folder. Production and the connector list one Function (stratus_upload), is_deployed=false, source not in repo.
Cron / scheduled jobs (sitemap regeneration, stale-content revalidation)	Missing	Catalyst List_All_Crons = []; no revalidate code in src.
Catalyst Search	Missing	No usage in code; filtering is in app code.
API Gateway rules for the Next.js APIs / throttling	Missing	Only one rule exists (stratus_upload, ANY).
Automated tests	Missing	No test files or script.
CI/CD pipeline	Missing	No .github/workflows; Catalyst Pipelines not queried.
.env.example / environment documentation	Missing	Not in repo.
Privacy Policy, Terms, Contact page	Missing	/privacy, /terms, /contact are 404; footer links /privacy-policy, /terms-of-use and /rera also 404 (browser link crawl).
Security headers	Missing	S-07.
Monitoring / alerting / error tracking	Missing	No Sentry, no health endpoint, no uptime or log shipping configured; Get_Logs for the Slate app returned empty in run 4 and build logs are not retrievable.
SalesIQ, PageSense, GA4/GTM, Search Console	Missing	No scripts or IDs in code (grep for salesiq|pagesense|gtag|dataLayer|googletagmanager).
Property JSON-LD (RealEstateListing/Product/Offer)	Missing	HEAD adds RealEstateAgent JSON-LD on /properties and metadata/canonical/OG on detail pages, but no listing-level JSON-LD; /shortlist canonicalises to non-existent /wishlist; canonical hard-codes https://anarock.com.
Buildable main branch / pre-merge checks	Missing	df46295 broke the build and was pushed to main with no CI to catch it; 14 commits landed at once.
README / docs	Present	README.md exists and was refreshed this run.
Cookie consent	Present (defective)	Banner exists; analytics and marketing default to enabled (pre-ticked); no trackers are gated because none exist.
Production deployment	Missing	Production Slate deployment failed 2026-10-14 and main HEAD currently cannot build; Development apps 'Anarock' and 'nextjs' both serve this code.

5. Accessibility (axe-core 4.10.2, WCAG 2.1 A/AA, desktop 1366 px and mobile 375 px)

Page / viewport result	Outcome
/	**Fail** aria-required-parent(critical,2), color-contrast(serious,3) | all: aria-required-parent:2,color-contrast:3
/aboutus	**Pass**
/properties	**Fail** select-name(critical,2) | all: select-name:2
/shortlist	**Pass**
/compare	**Pass**
/list-your-property	**Fail** select-name(critical,2) | all: select-name:2
/services	**Pass**
/kyc/city/delhi	**Fail** color-contrast(serious,2) | all: color-contrast:2
/properties/1/test-property	**Pass**
/	**Fail** aria-required-parent(critical,2), color-contrast(serious,3) | all: aria-required-parent:2,color-contrast:3
/aboutus	**Pass**
/properties	**Pass**
/shortlist	**Pass**
/compare	**Pass**
/list-your-property	**Fail** select-name(critical,2) | all: select-name:2
/services	**Pass**
/kyc/city/delhi	**Fail** color-contrast(serious,2) | all: color-contrast:2
/properties/1/test-property	**Pass**

Violations are reported once per page-run; the same rules repeat on desktop and mobile. 'serious' colour-contrast failures need design changes; select-name needs labels on filter <select> elements.

6. Limitations

- Review is static plus the executed runs described; the Catalyst Function source is not available, so back-end logic outside the Next.js app is not reviewed. - Listing and detail pages were rendered without data, so their populated states were not audited for accessibility. - No application code was changed.